

SmartVAPT Security Assessment Report

ICT Academy of Kerala - Cyber Security Analyst (VAPT)

Vulnerability Assessment Report

Target: <https://tryhackme.com/>

Date: September 25, 2026

1. Executive Summary

An automated Vulnerability Assessment and Penetration Testing (VAPT) scan of tryhackme.com identified foundational security gaps in email domain validation and web application security headers. While network services are minimal (HTTP/HTTPS) and leverage basic transport security (HSTS), the absence of a Sender Policy Framework (SPF) DNS record presents a high risk of domain spoofing and phishing attacks. Furthermore, key HTTP defense-in-depth headers are missing, increasing vulnerability to client-side attacks such as Cross-Site Scripting (XSS), Clickjacking, and MIME sniffing.

Overall Risk: **High (7.0/10)**

2. Top Findings

1. Missing SPF (Sender Policy Framework) Record [High]

Business Impact: Allows malicious actors to send forged emails appearing to originate from tryhackme.com. This enables targeted phishing, executive impersonation, and fraud against employees, partners, and users, posing severe brand reputation risk.

Remediation: Create and publish a restrictive SPF record in DNS listing all authorized email senders for tryhackme.com.

2. Missing Web Application Security Response Headers [Medium]

Business Impact: Leaves application users vulnerable to client-side attacks including Clickjacking, Cross-Site Scripting (XSS), data leakage through referrer headers, and unauthorized browser privilege access.

Remediation: Configure web delivery platforms (e.g., Vercel / Nginx) to enforce HTTP security headers across all web responses.

SmartVAPT Security Assessment Report

ICT Academy of Kerala - Cyber Security Analyst (VAPT)

3. Technical Remediation

1. Missing SPF Record (DNS-001) (A07:2021 - Identification and Authentication Failures)

- Audit all legitimate outbound email channels (e.g., Google Workspace, SendGrid, Mailchimp).
- Construct an SPF TXT record explicitly enumerating these authorized senders.
- Publish the TXT record to the domain's public DNS zone.

```
$ dig +short TXT tryhackme.com
```

```
$ DNS Record (TXT): tryhackme.com. IN TXT "v=spf1 include:_spf.google.com ~all"
```

2. Missing Content-Security-Policy Header (WEB-001) (A05:2021 - Security Misconfiguration)

- Define an appropriate directive set specifying trusted script, style, and media origins.
- Deploy the Content-Security-Policy HTTP header at the server or CDN level.

```
$ Vercel (vercel.json): { "headers": [ { "source": "/*.*", "headers": [ { "key": "Content-Security-Policy", "value": "default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval'; object-src 'none';" } ] } ] }
```

```
$ Nginx: add_header Content-Security-Policy "default-src 'self'; script-src 'self';" always;
```

3. Missing Clickjacking and Content Hardening Headers (WEB-002, WEB-003, WEB-004, WEB-005) (A05:2021 - Security Misconfiguration)

- Enforce X-Frame-Options to prevent framing (Clickjacking).
- Enforce X-Content-Type-Options to disable MIME-sniffing.
- Configure Referrer-Policy to protect sensitive URLs in referrer logs.
- Implement Permissions-Policy to restrict dangerous browser APIs.

```
$ X-Frame-Options: SAMEORIGIN
```

```
$ X-Content-Type-Options: nosniff
```

```
$ Referrer-Policy: strict-origin-when-cross-origin
```

```
$ Permissions-Policy: camera=(), microphone=(), geolocation=()
```

SmartVAPT Security Assessment Report

ICT Academy of Kerala - Cyber Security Analyst (VAPT)

4. Appendix: Scan Details

A. Target Information

Target: https://tryhackme.com/
Scan ID: 20260925_155232

B. Network Scan

Open Ports: 2
Total CVEs: 0
Severity: Critical: 0 | High: 0 | Medium: 0 | Low: 0

Host: 64.239.123.65 (tryhackme.com) State: up
Port 80/tcp: http Vercel
Port 443/tcp: http Golang net/http server

C. Web Application Scan

Server: Vercel
Missing security headers (5):

- Content-Security-Policy
- X-Frame-Options
- X-Content-Type-Options
- Referrer-Policy
- Permissions-Policy

Present security headers (1):

- Strict-Transport-Security: max-age=63072000

Detected technologies (2):

- Vercel (via header:Server)
- Next.js (via header:X-Powered-By)

TLS: TLSv1.3 Cipher: TLS_AES_128_GCM_SHA256
Valid until: Oct 22 02:34:13 2026 GMT

Redirect chain (1 hops):
200 https://tryhackme.com/

D. DNS / Email Security

Domain: tryhackme.com
SPF Present: No
DMARC Present: Yes
Record: v=DMARC1; p=quarantine; pct=5;
rua=mailto:3c01de90206f495794daaa800026b08d@dmARC-reports.cloudflare.net
Policy: quarantine